

Assignment No:- 1

Que -1] What do you mean by attacks, types of attacks and statistics of main vulnerabilities?

ANS: "Attacks" refer to attempts by malicious actors to exploit vulnerabilities in systems, networks, or applications to gain unauthorized access, steal data, disrupt services, or cause harm.

Types of Cyber Attacks

1. Malware Attacks:

- *Description:* Malicious software designed to damage, disrupt, or gain unauthorized access to a system.
- *Examples:* Viruses, Trojans, Ransomware, and Worms.

2. Phishing Attacks:

- *Description:* Social engineering attacks that involve tricking individuals into revealing sensitive information (like passwords) by pretending to be a trusted entity.
- *Examples:* Email phishing, Spear phishing, and Whaling (targeting high-profile individuals).

3. Denial of Service (DoS) and Distributed Denial of Service (DDoS) Attacks:

- *Description:* Overwhelming a target's resources, making it unavailable to legitimate users. DDoS attacks involve multiple systems attacking a single target.
- *Examples:* Flood attacks, Ping of Death, and Botnets.

4. Man-in-the-Middle (MitM) Attacks:

- *Description:* An attacker intercepts and potentially alters communication between two parties without them knowing.
- *Examples:* Session hijacking, Wi-Fi eavesdropping, and SSL stripping.

5. SQL Injection Attacks:

- *Description:* Attacks that inject malicious SQL code into a query to access or manipulate a database.
- *Examples:* Retrieving sensitive data, bypassing login authentication, and modifying database information.

6. Cross-Site Scripting (XSS) Attacks:

- *Description:* An attacker injects malicious scripts into websites to target users, stealing information or causing them to perform unintended actions.
- *Examples:* Reflected XSS, Stored XSS, and DOM-based XSS.

Statistics on Main Vulnerabilities

1. **Common Vulnerabilities and Exposures (CVE):** The CVE database tracks known vulnerabilities. Each CVE is assigned a score that reflects its severity, with higher scores indicating more critical vulnerabilities.
2. **Vulnerability Types:** Statistics often show that Injection flaws (like SQL injection) and Broken Authentication are among the most common vulnerabilities.
3. **Financial Impact:** According to reports from organizations like IBM and the Ponemon Institute, the average cost of a data breach can range from several million dollars, depending on the industry and the size of the breach.
4. **Attack Trends:** Ransomware attacks have seen a notable rise over recent years, with attackers often demanding significant sums of money to restore access to compromised systems.

Que -2] Study of different laws and standards of cyber security.

ANS: Cybersecurity laws and standards are designed to protect data, ensure privacy, and provide guidelines for organizations to manage security risks. They vary across countries and industries, and understanding these laws and standards is essential for compliance and for setting up effective security practice.

1.Cybersecurity Laws

Cybersecurity laws aim to protect individuals, organizations, and governments from cyber threats. Here are some of the most well-known:

a. General Data Protection Regulation (GDPR) - European Union

- *Overview:* GDPR is a comprehensive data protection law that applies to organizations handling the personal data of EU citizens.
- *Key Points:*
 - Requires organizations to obtain explicit consent for data processing.
 - Mandates reporting data breaches within 72 hours.
 - Imposes strict fines for non-compliance, up to 4% of global revenue or €20 million.
- *Purpose:* Protects individual privacy and gives individuals more control over their personal data.

b. Health Insurance Portability and Accountability Act (HIPAA) - United States

- *Overview:* HIPAA is designed to secure the privacy and security of patients' medical records and other health information.
- *Key Points:*
 - Applies to healthcare providers, health plans, and other related entities.
 - Sets standards for protecting electronically protected health information (ePHI).

- Enforces strict guidelines on data breach notification.
- *Purpose:* Protects patient health information from unauthorized access or disclosure.

c. Federal Information Security Management Act (FISMA) - United States

- *Overview:* FISMA requires federal agencies to protect information and systems from threats.
- *Key Points:*
 - Sets guidelines for creating, monitoring, and improving information security programs.
 - Mandates regular risk assessments and continuous monitoring.
 - Applies to federal agencies and contractors handling government data.
- *Purpose:* Ensures that government agencies protect their information and systems from cyber threats.

d. Personal Information Protection and Electronic Documents Act (PIPEDA) - Canada

- *Overview:* PIPEDA governs how private sector organizations collect, use, and disclose personal information.
- *Key Points:*
 - Applies to personal data of Canadian citizens.
 - Requires organizations to obtain consent for data collection and handling.
 - Enforces the right of individuals to access their personal information.
- *Purpose:* Protects Canadian citizens' personal data and privacy.

2. Cybersecurity Standards

Cybersecurity standards provide frameworks and guidelines to help organizations manage their security risks effectively. Some widely used standards include:

a. ISO/IEC 27001

- *Overview:* ISO 27001 is an international standard for managing information security.
- *Key Points:*
 - Focuses on establishing, implementing, maintaining, and improving an information security management system (ISMS).
 - Provides requirements for risk assessment, asset management, and incident response.
 - Certifiable by third-party audits, allowing organizations to demonstrate compliance.
- *Purpose:* Helps organizations protect their data and ensures continuous improvement in information security management.

b. National Institute of Standards and Technology (NIST) Cybersecurity Framework - United States

- *Overview:* The NIST Cybersecurity Framework provides a voluntary, risk-based approach for managing cybersecurity threats.
- *Key Points:*
 - Outlines five core functions: Identify, Protect, Detect, Respond, and Recover.
 - Widely used by U.S. federal agencies and private sector organizations.
 - Helps organizations build resilience and reduce the impact of cybersecurity incidents.
- *Purpose:* Enhances the security posture of organizations through practical, standardized processes.

c. Payment Card Industry Data Security Standard (PCI DSS)

- *Overview:* PCI DSS is a security standard for organizations handling credit card transactions.
- *Key Points:*
 - Requires organizations to implement specific controls for protecting cardholder data.
 - Covers aspects like access control, network security, and monitoring.
 - Non-compliance can result in fines and potential bans from processing credit card payments.
- *Purpose:* Protects payment card data from theft and fraud.

d. Center for Internet Security (CIS) Controls

- *Overview:* CIS Controls are a set of best practices for securing IT systems and data.
- *Key Points:*
 - Provides 20 critical security controls, ranging from inventory control to incident response.
 - Widely adopted by businesses and government agencies.
 - Tailored to help organizations prioritize security efforts.
- *Purpose:* Improves cybersecurity through practical guidelines and helps organizations defend against common cyber threats.

Que -3| Write a short on Threat Modeling.

ANS: Threats can be anything that can take advantage of a vulnerability to breach security and negatively alter, erase, or harm objects or objects of interest. Threat Modelling can be done at any stage of development but if done at the beginning it will help in the early determination of threats that can be dealt with properly.

Purpose of Threat Modeling

The purpose of Threat modeling is to identify, communicate, and understand threats and mitigation to the organization's stakeholders as early as possible. Documentation from this process provides system analysts and defenders with a complete analysis of probable attackers' profiles, the most likely attack vectors, and the assets most desired by the attacker.

Process of Threat Modeling**1. Aim**

The target before approaching Threat Modeling must be clear within ourselves what we will achieve from Threat Modeling, that is our application must follow the **CIA Triad**.

- Confidentiality: It helps in protecting data from unauthorized access.
- Integrity: It helps in preventing restricted changes.
- Availability: It helps in performing important tasks under certain attacks.

2. Visualization

Here, we will deal with what we are going to build. We must have a document overview of the application which helps in making our process easier. Here we will build diagrams that will help us in making our process easier.

It can be done in two ways:

- Data Flow Diagram: It helps in showing how the flow of data occurs in the system.
- Process Flow Diagram: It helps in finding the process of the system that from where users interact in the system, and how the system works internally.

3. Threat Identification

Here we are going to deal with how we can identify threats or what can go wrong in the process. By analyzing the images of the previous section, you have found how threats can be identified. These methods are mentioned in threat modeling methodologies..

4. Mitigation

Here, we are going to deal with what we will do about the Threats. Here we will review the layers to identify the required vulnerabilities. Mitigation involves a continuous investigation of each vulnerability so that the most effective efforts can be designed.

5. Validation

This is the final step in the process of Threat Modeling, here we are going to deal with whether we have done a good job or not. Have all the threats been mitigated or not? We will check the changes and as threat modeling is not a one-time activity, we have to regularly watch these things.

Que -4] Enlist and explain different top 5 methodologies and guidelines of OWASP (Open Web Application Security Project) for the secure application development.

ANS: The **Open Web Application Security Project (OWASP)** is a global nonprofit organization that focuses on improving software security. OWASP provides various resources, tools, and guidelines to help developers build secure applications.

1. OWASP Top Ten

- **Description:** The OWASP Top Ten is a list of the ten most critical security risks to web applications, updated periodically based on the latest threat landscape.
- **Purpose:** Serves as an awareness document to help organizations identify and mitigate the most common and impactful vulnerabilities.
- **Examples of Risks:**
 - *Injection Attacks:* Such as SQL, NoSQL, and OS Command Injections.
 - *Broken Authentication:* Issues that allow attackers to compromise user identities.
 - *Sensitive Data Exposure:* Failing to protect sensitive data with proper encryption.
- **Usage:** Organizations can use the OWASP Top Ten to guide security best practices, prioritize security measures, and educate developers on common vulnerabilities.

2. OWASP ASVS (Application Security Verification Standard)

- **Description:** The ASVS is a framework for testing the security of applications. It provides a comprehensive checklist of security requirements at different assurance levels (1, 2, and 3) to help assess the security posture of an application.
- **Purpose:** Helps organizations define, build, and verify secure applications through structured requirements.
- **Key Components:**
 - *Authentication:* Verifying user identity securely.
 - *Access Control:* Ensuring users access only the resources they're authorized for.
 - *Data Protection:* Protecting sensitive data in transit and at rest.
- **Usage:** The ASVS is used for secure design, security testing, and compliance to ensure that applications meet specific security standards.

3. OWASP SAMM (Software Assurance Maturity Model)

- **Description:** SAMM is a maturity model that provides a roadmap for organizations to improve their software security practices. It includes predefined activities that cover the entire software development lifecycle.
- **Purpose:** Helps organizations assess, improve, and measure their software security practices.
- **Key Phases:**
 - *Governance:* Establishing policies and strategy for secure development.
 - *Design:* Ensuring security is considered in architecture and design.
 - *Implementation:* Enforcing coding standards and secure development practices.
- **Usage:** Organizations use SAMM to evaluate their current security maturity level and identify areas for improvement.

4. OWASP Testing Guide

- **Description:** This guide offers a comprehensive methodology for security testing web applications. It covers testing techniques for a wide range of vulnerabilities and provides checklists to help security teams assess application security.
- **Purpose:** To help security testers and developers perform thorough security assessments and identify vulnerabilities before deployment.
- **Key Areas:**
 - *Information Gathering:* Collecting data about the application and its environment.
 - *Authentication Testing:* Verifying secure login mechanisms and session management.
 - *Client-Side Testing:* Ensuring security in front-end components and user data handling.
- **Usage:** The Testing Guide is commonly used in penetration testing and vulnerability assessments to ensure comprehensive security evaluations.

5. OWASP Proactive Controls

- **Description:** The OWASP Proactive Controls list outlines the top security controls that developers should include in their projects to prevent vulnerabilities.
- **Purpose:** Focuses on a developer-centric approach to security by encouraging secure coding practices from the start of the development process.
- **Top Controls:**
 - *Define Security Requirements:* Integrate security requirements into the development lifecycle.
 - *Leverage Security Frameworks and Libraries:* Use trusted frameworks and libraries to avoid writing insecure code.
 - *Implement Access Control:* Enforce robust authorization mechanisms and role-based access.

- **Usage:** The Proactive Controls list serves as a practical guideline for developers to adopt secure coding practices early on, ensuring that security is built into the application from the ground up.

Que -5] Enlist and explain Owasp Web Security Testing Guidelines.

ANS: The OWASP Web Security Testing Guide is a comprehensive framework for testing the security of web applications. It provides methodologies, techniques, and checklists to help security professionals and developers perform thorough assessments.

1. Information Gathering

- **Description:** This phase involves collecting data about the target application, including its structure, technologies, and functionality, to understand the attack surface.
- **Key Techniques:**
 - *DNS Interrogation:* Gathering information about domain names and IP addresses.
 - *Network Scanning:* Mapping the network to identify open ports and services.
 - *Application Fingerprinting:* Identifying web server versions, frameworks, and libraries in use.
- **Purpose:** Helps testers understand the environment and identify entry points for potential attacks.

2. Configuration and Deployment Management Testing

- **Description:** This phase assesses the application's configuration settings and deployment processes to ensure they are secure.
- **Key Techniques:**
 - *Test for Default Credentials:* Checking if the application is using default or weak credentials.
 - *Test for Security Misconfigurations:* Verifying that sensitive files (e.g., .git directories, backup files) are not accessible.
 - *Check for Unnecessary Services and Files:* Ensuring that unnecessary services or sample files are disabled or removed.
- **Purpose:** Ensures that the application and its environment are securely configured, reducing the risk of attacks due to misconfigurations.

3. Identity Management Testing

- **Description:** This phase focuses on testing how the application handles user identities, including registration, authentication, and account recovery processes.
- **Key Techniques:**

- *Test for Weak Password Policy*: Ensuring password policies are strong and enforceable.
- *Test for Multi-Factor Authentication (MFA)*: Verifying if MFA is implemented and working as expected.
- *Test for Account Lockout Mechanisms*: Ensuring that account lockout is in place to prevent brute-force attacks.
- **Purpose**: Validates the security of user accounts and the processes that manage them.

4. Authentication Testing

- **Description**: This phase examines how the application authenticates users and protects the authentication process from attacks.
- **Key Techniques**:
 - *Test for Credential Transmission over Insecure Channels*: Ensuring that passwords are not transmitted over HTTP or unencrypted channels.
 - *Test for Weak Session Management*: Checking if session IDs are protected against exposure and are regenerated on login.
 - *Test for Login Functionality Bypass*: Attempting to bypass the login process with common techniques like SQL injection.
- **Purpose**: Ensures that only legitimate users can access the application and that sessions are managed securely.

5. Authorization Testing

- **Description**: This phase assesses the application's access control mechanisms, verifying that users can only access resources and perform actions that they're authorized to.
- **Key Techniques**:
 - *Test for Vertical Authorization Issues*: Checking if users can access functionalities meant for higher privilege levels.
 - *Test for Horizontal Authorization Issues*: Ensuring that users can't access other users' data or perform unauthorized actions.
 - *Test for Insecure Direct Object References*: Checking for direct references to objects that don't enforce access controls.
- **Purpose**: Validates that the application enforces proper access controls to protect resources from unauthorized access.

6. Session Management Testing

- **Description**: This phase involves testing how the application manages user sessions, focusing on the security of session tokens.
- **Key Techniques**:

- *Test for Session Fixation*: Ensuring that session IDs are not reused across different sessions.
- *Test for Secure Cookie Flags*: Verifying that cookies are marked as secure and HttpOnly.
- *Test for Session Timeout*: Checking that sessions automatically expire after a period of inactivity.
- **Purpose**: Ensures that sessions are securely managed to prevent session hijacking and other attacks.

Que -6] Enlist and explain Tools for VAPT testing.

ANS: Vulnerability Assessment and Penetration Testing (VAPT) involves using a variety of tools to identify, assess, and exploit vulnerabilities in systems, networks, and applications.

1. Nmap (Network Mapper)

- **Description**: Nmap is an open-source network scanning tool that helps security professionals discover hosts and services on a network.
- **Key Features**:
 - *Port Scanning*: Identifies open ports and the services running on them.
 - *Operating System Detection*: Determines the operating systems of networked devices.
 - *Vulnerability Detection*: Can be used with scripts to detect common vulnerabilities.
- **Use Case**: Ideal for initial reconnaissance and network mapping, helping testers identify the attack surface of a target network.

2. Nessus

- **Description**: Nessus is a widely used vulnerability assessment tool developed by Tenable that scans for known vulnerabilities in systems and applications.
- **Key Features**:
 - *Comprehensive Scanning*: Detects thousands of vulnerabilities across different platforms.
 - *Detailed Reporting*: Generates detailed reports on discovered vulnerabilities.
 - *Compliance Audits*: Supports compliance checks for standards like PCI-DSS, HIPAA, and more.
- **Use Case**: Nessus is ideal for identifying and reporting vulnerabilities on a variety of systems, from servers to network devices.

3. Burp Suite

- **Description:** Burp Suite is a popular web application security testing tool that provides a suite of features for identifying, assessing, and exploiting vulnerabilities.
- **Key Features:**
 - *Proxy Interception:* Allows testers to intercept and modify traffic between the browser and the application.
 - *Scanner:* Automatically identifies common web vulnerabilities, such as XSS and SQL Injection.
 - *Repeater, Intruder, and Decoder:* Provides tools for testing specific web application functions.
- **Use Case:** Burp Suite is commonly used for web application penetration testing, allowing detailed inspection and testing of HTTP/S requests and responses.

4. Metasploit

- **Description:** Metasploit is an open-source penetration testing framework that allows testers to discover, exploit, and validate vulnerabilities.
- **Key Features:**
 - *Exploit Database:* Contains a vast library of exploits for different platforms.
 - *Payloads and Encoders:* Provides customizable payloads for exploitation.
 - *Post-Exploitation Modules:* Allows attackers to explore compromised systems further.
- **Use Case:** Metasploit is ideal for penetration testing, particularly for simulating real-world attacks and validating the impact of discovered vulnerabilities.

5. Wireshark

- **Description:** Wireshark is a network protocol analyzer that allows testers to capture and inspect data packets in real-time.
- **Key Features:**
 - *Packet Analysis:* Inspects individual packets to understand network traffic.
 - *Protocol Decoding:* Supports a wide range of network protocols for in-depth analysis.
 - *Filtering and Search:* Allows users to filter and search through captured data for specific patterns.
- **Use Case:** Useful for network vulnerability assessment, Wireshark helps testers analyze traffic for signs of attacks, such as man-in-the-middle attacks or data leaks.